

TLP:CLEAR

CVE-2025-62593 (Ray) — Premium Intelligence Canary

cve-2025-62593-ray-canary

NON-PRODUCTION RENDER-QA PREVIEW

Generated 2026-08-17T20:18:31.026Z

NOT the customer-facing deliverable

Table of Contents

1. Executive Summary
2. Scope and Methodology
3. Timeline
4. Vulnerability Details
5. Severity: Two Different Authoritative Scores
6. Exploitation Status: A Genuine Analytic Tension
7. Actor Context: RondoDox (general capability, not incident-specific)
8. Business Context
9. MITRE ATT&CK Mapping
10. Detection
11. Hunting
12. Forecast
13. Alternative Hypotheses
14. Intelligence Gaps
15. Technical Recommendations
16. Appendix A: Sources & Evidence Ledger

CVE-2025-62593 (Ray) — Premium Intelligence Canary

Classification: TLP:CLEAR — public vulnerability intelligence

Executive Summary

CVE-2025-62593 is a critical unauthenticated remote code execution vulnerability in Ray, a widely-adopted (237M+ downloads, PyTorch Foundation project) open-source AI/ML distributed compute engine, affecting versions prior to 2.52.0. CISA added this CVE to its Known Exploited Vulnerabilities catalog on 2026-08-17 with a 3-day remediation deadline (2026-08-20) under BOD 26-04, and CISA's own SSVC assessment records active exploitation. Real, directly-sourced evidence shows the RondoDox botnet attempted exploitation two days before public disclosure -- but the same research also documents a technical flaw in RondoDox's specific exploit payload that would likely cause it to fail against the actual defense. This report presents both findings and the resulting analytic tension explicitly, rather than resolving it by assumption.

Scope and Methodology

This report synthesizes seven independently retrieved sources: the GitHub Security Advisory (the CNA record), NVD's own REST API record, CISA's live KEV catalog feed, FIRST.org's EPSS API, Bitsight's RondoDox botnet infrastructure research, the PyTorch Foundation's official announcement of Ray's foundation adoption, and MITRE's own ATT&CK T1190 technique page. Six of the seven were retrieved as raw bytes via direct HTTP fetch and their `content_sha256` is computed programmatically from the checked-in raw files, never hand-typed. The seventh (the GitHub advisory) returned HTTP 403 to direct fetch and uses a reasoned excerpt-fingerprint fallback instead. Every claim in this report traces to at least one of these seven sources via an explicit `evidence_refs/source_refs` chain, visible in the Sources & Evidence Ledger appendix below. No claim in this report is drawn from model memory or generic industry knowledge about Ray, CVE severity conventions, or botnet behavior in general -- every specific figure, date, and quote is source-anchored.

Timeline

- **2025-05-25** — RondoDox botnet first observed (Bitsight research baseline start).
- **2025-10-22** — PyTorch Foundation announces Ray as a Foundation-hosted project; 237M+ cumulative downloads and 39,000+ GitHub stars stated at announcement.
- **2025-11-24** — RondoDox attempts to exploit CVE-2025-62593, two days before the CVE record is public -- Bitsight assesses this as evidence RondoDox tracks PoC/advisory publications directly rather than waiting on formal CVE assignment.
- **2025-11-26** — CVE-2025-62593 is publicly disclosed via GHSA-q279-jhrf-cc6v; fix ships in Ray 2.52.0.
- **2026-02-16** — End of Bitsight's RondoDox research period covering 174 exploits mapped to 148 CVEs.
- **2026-08-17** — CISA adds CVE-2025-62593 to the KEV catalog; CISA's own SSVC assessment records exploitation=active; FIRST.org's EPSS score stands at 0.369% (29.94th percentile) the same day.
- **2026-08-20** — CISA's BOD 26-04 remediation due date for this KEV entry.

Vulnerability Details

Root cause: Ray's job-submission API endpoints (`/api/jobs/`, `/api/job_agent/jobs/`) require no authentication. The only defense against browser-originated requests -- checking that the User-Agent header starts with 'Mozilla' -- is bypassable in Firefox and Safari via DNS rebinding, since the fetch specification permits arbitrary User-Agent values in those browsers. Exploitation requires three conditions together: a developer running Ray locally as a development tool, that developer using Firefox or Safari specifically (not Chrome, where the User-Agent header is more tightly locked down by the browser itself), and that developer's browser visiting an attacker-controlled or malvertising page. When those conditions align, a DNS-rebinding attack causes the victim's browser to resolve an attacker-registered domain to 127.0.0.1 after an initial same-origin check has already passed, at which point the page's script issues a POST carrying a spoofed User-Agent directly to the local Ray API -- achieving unauthenticated remote code execution on the developer's machine. CWE-94 (Code Injection) and CWE-352 (Cross-Site Request Forgery) both apply per NVD's own weakness classification. The vulnerability is fixed in Ray 2.52.0.

Severity: Two Different Authoritative Scores

GitHub's CNA-issued CVSS v4 score is 9.4 (Critical), vector

AV:N/AC:L/AT:N/PR:N/UI:P/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H -- notably UI:P (Passive user interaction). NVD's own primary CVSS v3.1 score, published independently by nvd@nist.gov rather than adopted from the CNA, is 8.8 (High), vector CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H -- UI:R (Required user interaction), with an exploitability sub-score of 2.8 and an impact sub-score of 5.9. Both figures are reported here rather than reconciled into one -- they reflect two different authoritative scorers applying two different CVSS versions with genuinely different assumptions about how much user interaction the DNS-rebinding delivery chain actually requires, not a data-quality defect in either source.

Exploitation Status: A Genuine Analytic Tension

CISA's own KEV addition and SSVC assessment (both dated 2026-08-17) record this CVE as under active exploitation, with automatable='no' and technicalImpact='total'. Independently, Bitsight's RondoDox botnet research documents that RondoDox attempted to exploit this exact CVE on 2025-11-24 -- two days before public disclosure on 2025-11-26 -- consistent with RondoDox tracking PoC and advisory publications directly rather than official CVE-database feeds. However, Bitsight's own technical analysis of RondoDox's specific payload found it sets the User-Agent header to 'Mozilla/5.0 (rondo2012@atomicmail[.]io)' -- a value that still starts with the literal string 'Mozilla', which is precisely the string the vulnerability's own defense checks for. A request carrying that User-Agent would trigger the vulnerability's HTTP 405 rejection path rather than bypass it, meaning RondoDox's specific, publicly-documented exploitation attempts against this CVE likely fail on the very defense the CVE describes as insufficient. Whether CISA's 'active' classification reflects attempts alone (consistent with what Bitsight documented, technical effectiveness notwithstanding) or confirmed compromise via other, non-public activity this review did not locate is not resolved here -- see Alternative Hypotheses below for the explicit weighing of both explanations. The EPSS probability is notably low (0.369%, 29.94th percentile) despite the KEV listing, underscoring that KEV addition, CVSS severity, and EPSS likelihood are three independent signals produced by three different methodologies that do not always move together -- a KEV listing reflects CISA's judgment that the vulnerability warrants federal-agency remediation priority, not a prediction of near-term exploitation probability, which is what EPSS specifically models.

Actor Context: RondoDox (general capability, not incident-specific)

RondoDox is a botnet first observed 2025-05-25 that has implemented 174 distinct exploits mapped to 148 CVEs as of Bitsight's research period ending 2026-02-16 (the remaining exploits corresponding to CVEs lacking public PoCs), peaking at 15,000 exploitation attempts in a single day. Its infrastructure comprises 32 identified IP addresses -- 16 used for exploitation, 16 for hosting, the hosting infrastructure built primarily on compromised residential IP addresses rather than conventional bulletproof hosting -- plus four identified command-and-control server IPs. Its operating pattern, per Bitsight, initially used a 'shotgun approach' of sending multiple exploits at a single target rather than fingerprinting first. Its primary targets are internet-exposed services and vulnerable IoT devices generally -- Ray, a developer-oriented AI compute engine typically run on a developer's own workstation rather than as an internet-facing service, is a notable departure from that typical target profile, and is itself a data point suggesting RondoDox's targeting has broadened beyond classic IoT/edge-device exploitation into developer-tooling supply chains. None of this general capability information is evidence of what happened, if anything, beyond the specific documented attempt against this CVE described above.

Business Context

Ray has been downloaded over 237 million times and carries more than 39,000 GitHub stars as of the PyTorch Foundation's 2025-10-22 announcement welcoming Ray as a Foundation-hosted project alongside PyTorch and vLLM, positioning it as one of three core layers (model development, inference, and distributed execution) of what the Foundation describes as a unified open source AI compute stack. Ray's own maintainer network traces to UC Berkeley, and it was originally commercialized by Anyscale. Uber's Director of Engineering, Zhitao Li, is quoted directly in the Foundation's own announcement confirming Ray 'has become a core part of our AI platform at Uber, powering large-scale model training, hyperparameter tuning, and distributed data processing.' This establishes a broad potential exposure surface across the AI/ML industry generally, and confirms at least one large, named production deployment context; it is not a claim that Uber or any other specific organization has been affected by this CVE -- no source reviewed connects any named organization to an actual incident.

MITRE ATT&CK Mapping

T1190 (Exploit Public-Facing Application, Initial Access, TA0001) is the closest available ATT&CK Enterprise technique for the RCE step, presented with an explicit caveat: MITRE's own description of T1190 specifies exploiting a weakness in 'an Internet-facing host or system,' while this CVE's actual initial-access pattern targets a locally-bound developer service (Ray's dashboard/API, typically bound to localhost or a private network interface) reached indirectly via browser-based DNS rebinding rather than direct Internet exposure. This is an atypical delivery mechanism no ATT&CK Enterprise technique reviewed cleanly covers -- it more closely resembles a browser-confused-deputy pattern than a classic Internet-facing-application exploit, even though the end result (unauthenticated remote code execution against a network service) is the same. T1190 is recorded here as the closest available analogue for cross-referencing purposes, not as a confident, precise mapping.

Detection

A Sigma detection concept is provided at SYNTAX_VALIDATED maturity only -- neither lab testing nor any deployment validation has been performed this session -- targeting the confirmed network-observable exploitation surface: an unauthenticated POST to /api/jobs/ or /api/job_agent/jobs/ from outside localhost. A match does not by itself confirm successful code execution; it flags the exact network-observable step common to every variant of this exploit chain, including any future corrected RondoDox payload. Full rule body:

YAML

```
title: Unauthenticated POST to Ray Jobs API Consistent with CVE-2025-62593
id: reportx-canary-cve-2025-62593-ray-jobs-api
status: experimental
description: >
  Detects an unauthenticated POST to Ray's /api/jobs/ or /api/job_agent/jobs/
  endpoint, the confirmed exploitation surface for CVE-2025-62593. A request
  matching this pattern does not by itself confirm successful code execution --
  it flags the exact network-observable step in the documented exploit chain.
references:
  - https://github.com/advisories/GHSA-q279-jhrf-cc6v
logsource:
  category: proxy
  product: ray-dashboard
detection:
  selection:
    http_method: POST
    url|contains:
      - '/api/jobs/'
      - '/api/job_agent/jobs/'
  filter_internal_client:
    src_ip|cidr: '127.0.0.1/32'
  condition: selection and not filter_internal_client
falsepositives:
  - Legitimate remote Ray job submission from an authorized orchestration client
level: high
```

Hunting

Given RondoDox's documented pre-disclosure exploitation attempt and its 4 identified C2 IPs and 16 identified exploiting IPs (Bitsight), a defensible hunting hypothesis for organizations running Ray in developer contexts is: search proxy/firewall logs for outbound or inbound traffic to/from those IP ranges around any POST to a local Ray API port, and separately, search browser/DNS logs for anomalously short-TTL DNS responses resolving to 127.0.0.1 or other loopback/private addresses immediately preceding a Ray API request -- the specific network signature of a DNS-rebinding attack chain. This report does not include RondoDox's specific IP addresses (Bitsight's blog post was reviewed for the aggregate counts and methodology cited above, not transcribed verbatim for a specific IOC list) -- teams operationalizing this hypothesis should pull current IOCs directly from Bitsight's own published research rather than from this summary.

Forecast

MEDIUM confidence that additional opportunistic scanning and exploitation attempts will continue over the next 90 days, including potential corrected exploit payloads that fix RondoDox's documented implementation flaw -- tempered by the currently low EPSS score and that specific flaw. See the structured forecast record (supporting observations, assumptions, counter-evidence, alternative scenarios, and indicators to watch) in the Claim Ledger appendix and this bundle's `forecasts` field.

Alternative Hypotheses

Two competing explanations for CISA's 'active' exploitation classification are weighed explicitly rather than resolved by assumption: **H1** that it reflects documented attempts regardless of technical success, consistent with and supported by the RondoDox evidence Bitsight published; versus **H2** that it reflects confirmed compromise via activity this review could not locate in open sources, supported only by CISA's own assessment taken at face value, and standing in tension with Bitsight's implementation-flaw finding, which argues against RondoDox specifically being a successful vector.

Intelligence Gaps

Three gaps are explicitly unresolved by any source reviewed for this report: whether any exploitation attempt against this CVE has technically succeeded; whether actors beyond RondoDox have attempted exploitation; and what fraction of Ray's 237M cumulative downloads represent deployments actually meeting this CVE's exploit prerequisites (a developer running Ray locally, using Firefox or Safari, reachable via a DNS-rebinding-capable browser session) as opposed to server-side, headless, or otherwise non-exploitable deployment patterns.

Technical Recommendations

1. Upgrade to Ray 2.52.0 or later (vendor-issued fix; evidence: c-fixed-version).
2. Restrict network exposure of the Ray dashboard/API to trusted networks as a compensating control where immediate upgrade is not feasible (evidence: c-root-cause, c-exploit-prereqs) -- this is generic hardening guidance, not a substitute for the vendor patch.

Appendix A: Sources & Evidence Ledger

Every source registered in this report's evidence graph, its retrieval/integrity metadata, and every captured excerpt tied to it -- the complete evidentiary basis for every claim above.

s-ghsa — GitHub Security Advisory Database / ray-project

- URL: <https://github.com/advisories/GHSA-q279-jhrf-cc6v>
- Type: VENDOR_CNA
- Reliability: HIGH
- Retrieved: 2026-08-17T00:00:00Z
- excerpt_fingerprint_sha256: d2a4738bacde095679bc91d89c804d0b560b800efbd0591f16019359eb2b1df8 (fallback reason: Direct HTTP fetch returned HTTP 403 (github.com blocks unauthenticated advisory-page scraping) this session; full content_sha256 could not be captured. Falling back to a fingerprint of the exact excerpt text relied upon, per evidence_integrity.py's documented policy.)

CVSS v4 Score: 9.4 (Critical). Vector: AV:N/AC:L/AT:N/PR:N/UI:P/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H

Affected Versions: < 2.52.0. Fixed Version: 2.52.0.

Exploitable against a developer running Ray who visits a malicious website or malvertising; DNS rebinding defeats the User-Agent 'Mozilla' prefix check; unauthenticated POST to /api/jobs/ executes arbitrary code.

A detailed PoC is provided; the advisory does not state confirmed real-world exploitation beyond that PoC.

s-nvd — NVD (NIST)

- URL: <https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2025-62593>
- Type: NVD
- Reliability: HIGH
- Retrieved: 2026-08-17T00:00:00Z
- content_sha256: cf983c003d94fd6ca8da9aa8a9d6791b599ad1e232fbb84c42bee336a34b763b

cvssMetricV31 (Primary, nvd@nist.gov): baseScore 8.8, baseSeverity HIGH, vector CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H, exploitabilityScore 2.8, impactScore 5.9.

weaknesses: CWE-94, CWE-352 (source: security-advisories@github.com).

ssvcV203 (role: CISA Coordinator, timestamp 2026-08-17T17:40:04.986785Z): exploitation=active, automatable=no, technicalImpact=total.

references include <https://www.bitsight.com/blog/rondodox-botnet-infrastructure-analysis> and https://www.cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2025-62593.

s-cisa-kev — CISA

- URL: https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json
- Type: CISA
- Reliability: HIGH
- Retrieved: 2026-08-17T00:00:00Z
- content_sha256: 93b107c2b076bc00d6f554d588a95633cc5a7dd6568b86c6d23ab37dd580267e

cveID CVE-2025-62593; vendorProject Ray-Project; dateAdded 2026-08-17; dueDate 2026-08-20; requiredAction cites BOD 26-04 'Prioritizing Security Updates Based on Risk'; knownRansomwareCampaignUse: Unknown.

s-first-epss — FIRST.org (Forum of Incident Response and Security Teams)

- URL: <https://api.first.org/data/v1/epss?cve=CVE-2025-62593>
- Type: OTHER
- Reliability: HIGH
- Retrieved: 2026-08-17T00:00:00Z
- content_sha256: 51bf70ffa34d2754c65959a913fdcf068fc2ceecf68660250b52e8598100d74

epss: 0.003690000, percentile: 0.299420000, date: 2026-08-17.

s-bitsight — Bitsight

- URL: <https://www.bitsight.com/blog/rondodox-botnet-infrastructure-analysis>
- Type: CTI_VENDOR_RESEARCH
- Reliability: MODERATE
- Retrieved: 2026-08-17T00:00:00Z
- content_sha256: fd34ee4903c722707b6ed16832ca3014cb34c108296dd4ccc6d7b65c02a43792

CVE-2025-62593 was exploited before the CVE was published -- specifically on 2025-11-24, two days before the official disclosure on 2025-11-26.

The exploit used by RondoDox specifically sets the User-Agent to 'Mozilla/5.0 (rondo2012@atomicmail[.]io)' which will render the exploit ineffective, since the vulnerability's defense checks for 'Mozilla' in the User-Agent and returns HTTP 405 when present.

RondoDox first observed 2025-05-25; peak 15,000 exploitation attempts in a single day; 174 exploits mapped to 148 CVEs; 32 identified IPs (16 exploiting, 16 hosting, primarily compromised residential IPs); 4 C2 IPs; primary targets internet-exposed services and vulnerable IoT devices; research period 2025-05-25 to 2026-02-16.

s-pytorch-foundation — PyTorch Foundation / Linux Foundation

- URL: <https://pytorch.org/blog/pytorch-foundation-welcomes-ray-to-deliver-a-unified-open-source-ai-compute-stack/>
- Type: OTHER
- Reliability: HIGH
- Retrieved: 2026-08-17T00:00:00Z
- content_sha256: 662ef46bba391b45360e57767a5f9ff01c12a2c9228087f9483bb4b06fa6083f

'Ray has already been adopted widely with 237 million downloads to date' ... 'over 39,000 GitHub stars.' PyTorch Foundation welcomed Ray 2025-10-22.

Zhitao Li, Director of Engineering, Uber: 'Ray has become a core part of our AI platform at Uber, powering large-scale model training, hyperparameter tuning, and distributed data processing.'

s-mitre-t1190 — MITRE ATT&CK

- URL: <https://attack.mitre.org/techniques/T1190/>
- Type: MITRE
- Reliability: HIGH
- Retrieved: 2026-08-17T00:00:00Z
- content_sha256: 8f496d7a86d2394f25b329b8d17fe0d0f9a413bb6dfed0ccf558146f50a43f96

T1190, Exploit Public-Facing Application, Initial Access (TA0001): 'Adversaries may attempt to exploit a weakness in an Internet-facing host or system to initially access a network.'